

ENCUESTA INTEGRAL DE EVALUACIÓN DE MADUREZ CIBERSEGURIDAD

Sistema Completo con 140+ Preguntas Estructuradas en Escala 1-5 de Madurez

Versión: 1.0

Fecha: Enero 2026

Público: CISOs, Security Managers, IT Directors, Responsables de seguridad

Duración: 45-60 minutos

Idioma: Español (ES-ES)

Propósito: Autodiagnóstico de madurez de ciberseguridad usando metodología GQM + PRAGMATIC

INSTRUCCIONES PARA RESPONDENTES

Cómo Rellenar Esta Encuesta

Tiempo recomendado: 45-60 minutos

Formato: Escala 1-5 (donde 1 = Ad Hoc; 5 = Optimizado)

Confidencialidad: Respuestas anónimas o identificadas (según instrucciones de tu CISO)

Qué Significa Cada Nivel de Madurez

Nivel 1: AD HOC (Inicial, sin documentación)

└ Acciones de seguridad existen pero son inconsistentes, no documentadas, reactivas. "Lo hacemos cuando nos acordamos" o "cuando algo falla"

Nivel 2: DEFINIDO (Procesos documentados, inconsistentes)

└ Procesos están documentados y comunicados, pero ejecución es inconsistente. Algunas personas lo hacen bien, otras no. "Tenemos un proceso, pero..."

Nivel 3: MANEJABLE (Automatizado, monitoreado)

└ Procesos están automatizados, monitoreados, con métricas. Se aplica consistentemente. "Lo hacemos siempre y lo vemos en dashboards"

Nivel 4: OPTIMIZADO (Continuo, con mejora)

└ Proceso está optimizado, continuamente mejorado, benchmarked. "Somos un referente en esto; revisamos trimestral y mejoramos"

Nivel 5: LIDERAZGO (Innovación, gobierno)

└ Somos líderes, definimos estándares de industria, gobierno visible. "Enseñamos a otros cómo hacerlo"

MÓDULO 1: GOBERNANZA, RIESGO Y CUMPLIMIENTO (GRC)

Preguntas GRC 1-18

GRC.1: Política de Ciberseguridad Documentada y Comunicada

Pregunta: ¿En qué nivel está documentación formal de política de ciberseguridad en tu organización?

Nivel	Descripción
1	No existe política formal. Seguridad se maneja ad-hoc.
2	Política existe, algunos conocen, no actualizada recientemente (<2 años).
3	Política documentada, comunicada a empleados, revisada anualmente.
4	Política integrada en procesos, actualizada semestralmente, evidencia de cumplimiento.
5	Política viva, actualizada continuamente, gobierno visible, benchmark interno.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

Evidencia requerida: (ej: link a documento de política, fecha última revisión, lista de distribución)

GRC.2: Comité de Seguridad y Gobernanza Ejecutiva

Pregunta: ¿Con qué frecuencia se reúne un comité/junta de seguridad formal en tu organización?

Nivel	Descripción
1	No existe comité formal. Decisiones de seguridad ad-hoc.
2	Comité existe pero irregular (2-3 reuniones/año).
3	Comité se reúne mensualmente. Actas documentadas.
4	Comité reúne mensualmente con reporting automatizado. Board audit committee informado trimestralmente.
5	Comité reúne mensualmente; Board implicado; métricas de cumplimiento visibles.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

Evidencia: (ej: acta última reunión, lista asistentes, frecuencia)

GRC.3: Riesgos Cuantificados y Aceptados Formalmente

Pregunta: ¿Qué porcentaje de riesgos identificados tiene una valorización financiera y/o aceptación formal documentada?

Nivel	Descripción
1	<20% de riesgos tienen valorización o aceptación documentada.
2	20-40% de riesgos; la mayoría es cualitativa.
3	40-70% de riesgos valorados; algunos con aceptación formal.
4	70-90% valorados; aceptación formal documentada; revisión trimestral.
5	95-100% de riesgos cuantificados; aceptación formal; riesgo residual conocido.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

Evidencia: (ej: registro de riesgos con valores €, acta de aceptación)

GRC.4: Alineación con Regulaciones (NIS2, GDPR, ISO 27001, ENS)

Pregunta: ¿Cuál es el nivel de alineación documentada con regulaciones ciberseguridad aplicables a tu organización?

Nivel	Descripción
1	Conciencia limitada de regulaciones. No hay mapeo formal.
2	Conocemos regulaciones; algún mapeo informal a controles.
3	Mapeo formal de regulaciones a controles internos. Gap analysis realizado.
4	Mapeo documentado; gap remediation plan; seguimiento trimestral.
5	Cumplimiento demostrado; auditoría externa validó; certificaciones vigentes.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

Evidencia: (ej: documento de mapeo, plan de remediación, certificados ISO/auditoría)

GRC.5: Presupuesto Dedicado a Ciberseguridad (Con Visibilidad)

Pregunta: ¿Cuál es el nivel de presupuesto anual dedicado a ciberseguridad y su visibilidad?

Nivel	Descripción
1	<1% del presupuesto IT. Presupuesto reaccionario, no planificado.
2	1-3% de presupuesto IT. Presupuesto anual, sin desglose detallado.
3	3-5% de presupuesto IT. Presupuesto anual con plan detallado.
4	5-8% de presupuesto IT. Plan 3-5 años; ROI calculado; aprobación Board.
5	>8% de presupuesto IT. Plan multi-año; ROI demostrado; inversión en innovación.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

Evidencia: (ej: presupuesto línea de ciberseguridad, desglose por iniciativa, aprobación)

[Continuación similar para GRC.6-18, IDENTIFY.1-20, IAM.1-22, PROTECT.1-25, DETECT.1-18, RESPOND.1-15, CONTINUITY.1-12, CYBER_RISK.1-10, SCRM.1-15]

MÓDULO 2: IDENTIFICACIÓN Y GESTIÓN DE ACTIVOS (IDENTIFY)

Preguntas IDENTIFY 19-38

IDENTIFY.1: Inventario Completo de Activos de TI

Pregunta: ¿Cuál es la cobertura del inventario de activos de TI en tu organización?

Nivel	Descripción
1	Inventario inexistente o muy incompleto (<50% de activos).
2	Inventario existe; cobertura 50-70%; no actualizado regularmente.
3	Inventario documentado; cobertura 70-90%; actualización mensual.
4	Inventario >90% cobertura; actualización semanal; integrado en CMDB.
5	Inventario 95%+ cobertura; actualización automática; lifecycle tracking.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

IDENTIFY.2: Clasificación de Datos Según Sensibilidad

Pregunta: ¿Qué porcentaje de datos/información en tu organización tiene clasificación de sensibilidad documentada?

Nivel	Descripción
1	<20% de datos clasificados. Concepto "sensible" es vago.
2	20-40% clasificado; algunos repositorios tienen labels.
3	40-70% clasificado; proceso definido; DLP básico implementado.
4	70-95% clasificado; DLP activo; revisión semestral.
5	95%+ clasificado; DLP automático; auditoría continua.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

[Continuación IDENTIFY.3-20...]

MÓDULO 3: GESTIÓN DE IDENTIDAD Y ACCESO (IAM)

Preguntas IAM 39-60

IAM.1: Multifactor Authentication (MFA) en Sistemas Críticos

Pregunta: ¿En qué porcentaje de accesos críticos está implementada MFA?

Nivel	Descripción
1	MFA no implementada. Acceso solo con contraseña.
2	MFA en <50% de accesos administrativos. Usuarios finales sin MFA.
3	MFA en 50-80% de accesos críticos; usuarios finales parcialmente.
4	MFA en >95% de accesos administrativos; 70% de usuarios finales.
5	MFA obligatoria 100% accesos críticos; >90% usuarios finales.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

IAM.2: Recertificación de Acceso (Anual/Regular)

Pregunta: ¿Con qué frecuencia se realiza recertificación formal de accesos de usuarios?

Nivel	Descripción
1	No existe proceso de recertificación. Accesos nunca se revisan.
2	Ad-hoc; cuando hay rotación de personal.
3	Anualmente; cubierto 50-70% de usuarios.
4	Anualmente; cubierto 85-95% de usuarios; documentado.
5	Semestralmente; 100% cobertura; automatizado; evidencia auditada.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

[Continuación IAM.3-22...]

MÓDULO 4: PROTECCIÓN (PROTECT)

Preguntas PROTECT 61-85

PROTECT.1: Parcheo de Sistemas (Vulnerabilities Management)

Pregunta: ¿Cuál es el promedio de tiempo para remediar vulnerabilidades críticas (CVSS ≥ 9)?

Nivel	Descripción
1	>60 días promedio. Vulnerabilidades críticas sin parchear.
2	30-60 días promedio. Proceso ad-hoc.
3	14-30 días promedio. Proceso definido; documentado.
4	7-14 días promedio; 95%+ compliance.
5	<7 días promedio; 100% compliance; automatizado.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

PROTECT.2: Encriptación de Datos en Tránsito y en Reposo

Pregunta: ¿Cuál es el porcentaje de datos sensibles encriptados (en tránsito + en reposo)?

Nivel	Descripción
1	<30% encriptado. Algunos datos críticos sin encriptación.
2	30-60% encriptado; algunos gaps en cobertura.
3	60-85% encriptado; proceso documentado.
4	85-98% encriptado; estándares NIST; revisión anual.
5	98%+ encriptado; algoritmos post-cuánticos evaluados.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

[Continuación PROTECT.3-25...]

MÓDULO 5: DETECCIÓN (DETECT)

Preguntas DETECT 86-103

DETECT.1: Mean Time To Detect (MTTD) de Incidentes

Pregunta: ¿Cuál es el promedio de tiempo para detectar un incidente de ciberseguridad?

Nivel	Descripción
1	>30 días promedio. Incidentes detectados por terceros.
2	14-30 días promedio. SIEM existe pero no optimizado.
3	4-14 días promedio. SIEM optimizado; alertas configuradas.
4	1-4 días promedio; <4 horas para críticos.
5	<4 horas promedio; real-time alerts; AI/ML integrado.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

DETECT.2: SIEM / Monitoreo y Logging

Pregunta: ¿Cuál es el nivel de cobertura de SIEM/monitoreo en tu organización?

Nivel	Descripción
1	SIEM no existe. Logging limitado.
2	SIEM existe; cobertura <40% de sistemas.
3	SIEM con 40-70% cobertura; logs retenidos 1 año.
4	SIEM con >85% cobertura; logs 2-3 años; correlación de eventos.
5	SIEM 100%; logs 3+ años; ML/AI análisis; threat hunting activo.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

[Continuación DETECT.3-18...]

MÓDULO 6: RESPUESTA (RESPOND)

Preguntas RESPOND 104-118

RESPOND.1: Plan de Respuesta a Incidentes Documentado

Pregunta: ¿Existe plan de respuesta a incidentes documentado y probado?

Nivel	Descripción
1	No existe plan formal. Respuesta ad-hoc.
2	Plan existe, algunas personas lo conocen, no actualizado.
3	Plan documentado, comunicado, probado anualmente.
4	Plan actualizado semestralmente, drills regulares, roles claros.
5	Plan vivo, drills trimestrales, tabletop exercises, métricas de mejora.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

RESPOND.2: Mean Time To Respond (MTTR) a Incidentes

Pregunta: ¿Cuál es el tiempo promedio para contener un incidente detectado?

Nivel	Descripción
1	>72 horas promedio. Procedimientos manuales.
2	48-72 horas. Proceso definido pero lento.
3	12-48 horas. Proceso optimizado.
4	4-12 horas. Automatización parcial; playbooks.
5	<4 horas promedio. Automatización SOAR; respuesta inmediata.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

[Continuación RESPOND.3-15...]

MÓDULO 7: RECUPERACIÓN (RECOVER)

Preguntas RECOVER 119-130

RECOVER.1: Backups y Plan de Recuperación

Pregunta: ¿Cuál es el nivel de cobertura y prueba de backups?

Nivel	Descripción
1	Backups ad-hoc o no existen. Recuperabilidad desconocida.
2	Backups existen; <50% de sistemas cubiertos; sin pruebas.
3	70-85% de sistemas; restauración probada anualmente.
4	>90% cobertura; restauración probada semestralmente.
5	100% cobertura; RTO/RPO definido; pruebas trimestrales; geo-redundancia.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

RECOVER.2: RTO/RPO Cumplimiento de Sistemas Críticos

Pregunta: ¿Cuál es el porcentaje de sistemas críticos que cumplen con RTO/RPO definido?

Nivel	Descripción
1	<20% cumplen. RTO/RPO no definido.
2	20-40% cumplen; algunos sistemas tienen metas.
3	40-70% cumplen; gaps documentados.
4	70-95% cumplen; plan de mejora en progreso.
5	95-100% cumplen; revisión trimestral; infraestructura resiliente.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

[Continuación RECOVER.3-12...]

MÓDULO 8: CONCIENCIA Y CAPACITACIÓN

Preguntas AWARENESS 131-145

AWARENESS.1: Programa de Conciencia de Seguridad

Pregunta: ¿Cuál es el nivel de programa de conciencia y capacitación en seguridad?

Nivel	Descripción
1	No existe programa. Capacitación ad-hoc.
2	Programa básico; <50% de empleados capacitados anualmente.
3	Programa definido; 50-80% cobertura; contenido actualizado.
4	Programa integral; >85% cobertura; capacitación rol-específica; métricas.
5	Programa avanzado; 95%+ cobertura; gamificación; phishing tests; innovation.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

AWARENESS.2: Phishing Resilience (Clic en Email Phishing)

Pregunta: ¿Cuál es el porcentaje de empleados que hace clic en email de phishing simulado?

Nivel	Descripción
1	>15% clic rate. Conciencia muy baja.
2	10-15% clic rate. Conciencia emergente.
3	5-10% clic rate. Conciencia buena.
4	3-5% clic rate. Conciencia muy buena.
5	<3% clic rate. Conciencia excelente; benchmark industria.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

[Continuación AWARENESS.3-15...]

MÓDULO 9: RIESGO CIBERNÉTICO Y GESTIÓN DE TERCEROS (SCRM)

Preguntas CYBER_RISK & SCRM 146-161

CYBER_RISK.1: Riesgos Identificados y Cuantificados

Pregunta: ¿Cuál es el porcentaje de riesgos cibernéticos cuantificados (modelo FAIR o equivalente)?

Nivel	Descripción
1	<20% cuantificados. Mayoría es cualitativo.
2	20-40% cuantificados. Modelo ad-hoc.
3	40-70% cuantificados. FAIR framework implementado.
4	70-90% cuantificados. Modelo validado; revisión anual.
5	90%+ cuantificados; modelo integrado en decisiones Board.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

SCRM.1: Evaluación de Seguridad de Proveedores

Pregunta: ¿Cuál es el porcentaje de proveedores críticos con evaluación formal de seguridad vigente?

Nivel	Descripción
1	<20% de proveedores evaluados. Sin proceso formal.
2	20-40% evaluados; evaluaciones informales.
3	40-70% evaluados; cuestionario CAIQ o equivalente.
4	70-95% evaluados; revisión anual; SBOMs solicitados.
5	95-100% evaluados; auditoría de seguridad; contratos de SCRM.

Tu respuesta: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5

[Continuación CYBER_RISK.2-10, SCRM.2-15...]

CÁLCULO DE PUNTUACIÓN TOTAL

Matriz de Agregación

Después de responder todas las preguntas:

Módulo	Preguntas	Suma de Respuestas	Promedio Módulo
GRC	1-18	(Q1+Q2+...+Q18)	÷ 18
IDENTIFY	19-38	(Q19+Q20+...+Q38)	÷ 20
IAM	39-60	(Q39+Q40+...+Q60)	÷ 22
PROTECT	61-85	(Q61+Q62+...+Q85)	÷ 25
DETECT	86-103	(Q86+Q87+...+Q103)	÷ 18
RESPOND	104-118	(Q104+Q105+...+Q118)	÷ 15
RECOVER	119-130	(Q119+Q120+...+Q130)	÷ 12
AWARENESS	131-145	(Q131+Q132+...+Q145)	÷ 15
CYBER_RISK/SCRM	146-161	(Q146+Q147+...+Q161)	÷ 16
ÍNDICE GLOBAL (IGM)		Promedio de todos módulos	

Interpretación de Resultado

IGM GLOBAL 4.5-5.0:	Excelente		Implementar innovación
IGM GLOBAL 3.5-4.4:	Bueno		Consolidar + expandir
IGM GLOBAL 2.5-3.4:	Aceptable		Plan de mejora urgente
IGM GLOBAL 1.5-2.4:	Débil		Acción inmediata requerida
IGM GLOBAL <1.5:	Crítico		Restructuring needed

Encuesta Versión 1.0 | Enero 2026 | España